

IPsec (IP Security)

CSE 717 Information Security — Past-Paper Solutions (2020, 2021, 2024)

Source: Lc#7 pp.14–21 Yield: 3/5 years (2020, 2021, 2024), 2.25–9 marks

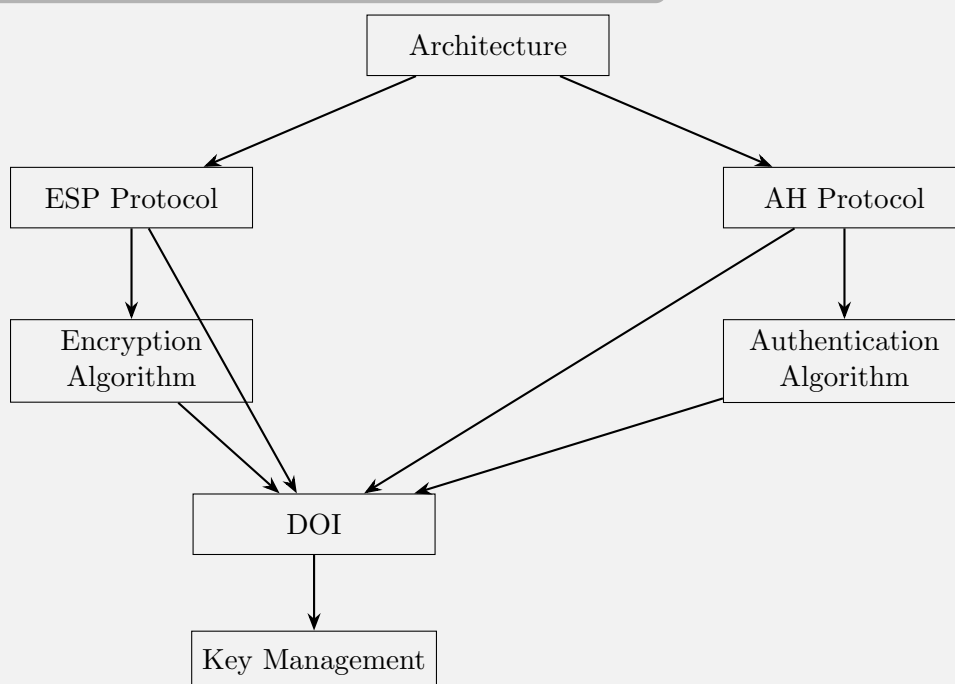
Cheat Sheet

IPsec Architecture — 7 Components

1. **Architecture** — general concepts, definitions, protocols, algorithms, security requirements
2. **ESP Protocol** (Encapsulation Security Payload) — provides **Confidentiality** service
3. **Encryption Algorithm** — documents describing algorithms used for ESP
4. **AH Protocol** (Authentication Header) — provides **Authentication + Integrity** services
5. **Authentication Algorithm** — documents for auth algorithm used by AH and auth option of ESP
6. **DOI** (Domain of Interpretation) — identifier supporting both AH and ESP; contains values needed for documentation
7. **Key Management** — describes how keys are exchanged between sender and receiver

Three services provided: Confidentiality Authentication Integrity

IPsec Architecture Diagram (Lc#7 Slide 16)



Security Associations (SA)

A **Security Association (SA)** is a one-way logical connection between communicating endpoints that provides security services for traffic carried on it.

An SA is uniquely identified by three parameters:

1. **SPI** (Security Parameters Index) — a 32-bit identifier in the AH/ESP header
2. **Destination IP Address** — unicast address of the receiving endpoint
3. **Security Protocol Identifier** — AH or ESP

One-way nature: Each SA is unidirectional. For bidirectional secure communication between two hosts, **two SAs** are required (one in each direction).

SA contains: sequence number counter, anti-replay window, AH/ESP algorithm + keys, IPsec protocol mode (transport/tunnel), SA lifetime.

Transport Mode vs Tunnel Mode

	Transport Mode	Tunnel Mode
What it protects	IP payload only	Entire original IP packet
IP header	Original header unchanged	New outer IP header added
Use case	End-to-end between two hosts	Gateway-to-gateway (VPN)
Overhead	Lower	Higher (extra IP header)

RFC 4301 Services (6 Security Services)

1. **Access control** — controls which packets are allowed through
2. **Connectionless integrity** — detects modification of individual IP datagrams
3. **Data origin authentication** — verifies identity of the sender
4. **Rejection of replayed packets (anti-replay)** — detects and rejects replayed datagrams via sequence number
5. **Confidentiality (encryption)** — encrypts IP payload
6. **Limited traffic flow confidentiality** — limits exposure of traffic patterns (in tunnel mode)

Application Areas of IPsec

1. **Secure branch-office connectivity** (site-to-site VPN) — securely connects remote offices over the Internet
2. **Secure remote access** (remote-access VPN) — employees access corporate network from home/travel
3. **Extranet / partner connectivity** — secure B2B communication with trading partners
4. **Enhanced e-commerce security** — protects transactions between customers and servers

2024 Exam (Q5(c) — 3 marks)

Section B Q5(c) — 3 marks: Architecture + Security Associations

2024 Section B Q5(c) [3 marks]

Explain the IPsec architecture and the role of security associations.

Solution

IPsec Architecture:

IPsec (IP Security) architecture uses two protocols to secure data flow:

- **ESP** (Encapsulation Security Payload) — provides **confidentiality**
- **AH** (Authentication Header) — provides **authentication and integrity**

The architecture includes four supporting documents:

- **Encryption Algorithm** — describes encryption for ESP
- **Authentication Algorithm** — describes auth algorithm for AH and ESP
- **DOI** (Domain of Interpretation) — identifier supporting both AH and ESP
- **Key Management** — describes key exchange between sender and receiver

Role of Security Associations (SA):

A **Security Association** is a one-way logical connection that defines the security parameters for traffic between two endpoints. It is uniquely identified by:

1. SPI (Security Parameters Index)
2. Destination IP address
3. Security protocol (AH or ESP)

An SA is **unidirectional** — two SAs are needed for bidirectional communication. Each SA specifies the cryptographic algorithm, keys, and mode (transport or tunnel) to be used.

2021 Exam (Q4(b,c) — 5 marks total)

Section B Q4(b) — 2.5 marks: Application Areas + Session vs Connection State

2021 Section B Q4(b) [2.5 marks]

Describe the application areas of IPsec and explain the distinction between session state and connection state in IPsec.

Solution

Application Areas of IPsec:

1. **Secure branch-office connectivity** — IPsec tunnel mode connects remote offices to HQ over the Internet, creating a site-to-site VPN.
2. **Secure remote access** — remote employees use IPsec to access internal corporate resources securely from home or while traveling.
3. **Extranet/partner connectivity** — businesses use IPsec to securely com-

municate with trading partners.

4. **Enhanced e-commerce** — protects financial transactions and customer data.

Session State vs Connection State:

- A **connection** refers to the state maintained for a single one-way IP flow protected by a specific Security Association (SA). Each SA has its own sequence numbers, keys, and lifetime.
- A **session** is a higher-level concept representing bidirectional communication between two parties. Since each SA is one-way, a session requires **two connections (two SAs)**.
- IPsec operates at the IP (network) layer and is **connectionless** at the packet level — each packet is individually secured based on the SA, without requiring a persistent TCP-style connection.

Section B Q4(c) — 2.5 marks: Architecture

2021 Section B Q4(c) [2.5 marks]

Describe the IPsec architecture.

Solution

IPsec Architecture provides security services at the IP layer using two protocols and four supporting documents:

Protocols:

- **ESP (Encapsulation Security Payload)** — encrypts the IP payload to provide confidentiality.
- **AH (Authentication Header)** — provides authentication and integrity without encryption.

Supporting Documents:

- **Encryption Algorithm** — specifies encryption algorithms used with ESP.
- **Authentication Algorithm** — specifies auth algorithms for AH and the auth option of ESP.
- **DOI (Domain of Interpretation)** — identifier that supports both AH and ESP; contains values for cross-referencing security parameters.
- **Key Management** — documents how session keys are securely exchanged between communicating parties.

Together these components provide three core services: **confidentiality**, **authentication**, and **integrity**.

2020 Exam (Q8 — 8.75 marks total)

Q8(a) — 2.25 marks: Benefits + Transport vs Tunnel Mode

2020 Q8(a) [2.25 marks]

What are the benefits of IPsec? Explain transport mode and tunnel mode.

Solution**Benefits of IPsec:**

- **Confidentiality** — encrypts data so eavesdroppers cannot read it (via ESP).
- **Authentication** — verifies the sender's identity (via AH or ESP auth option).
- **Integrity** — ensures data is not tampered with in transit.
- **Anti-replay protection** — prevents replay attacks via sequence numbers.
- **Access control** — filters which traffic is permitted through the gateway.

Transport Mode:

- Protects only the **IP payload** (not the original IP header).
- The original IP header is left unchanged and transmitted as-is.
- Used for **end-to-end** communication between two hosts.
- Lower overhead.

Tunnel Mode:

- Encapsulates the **entire original IP packet** (header + payload) inside a new IP packet.
- A new outer IP header is added, hiding the original source/destination.
- Used for **gateway-to-gateway** VPN (site-to-site tunnels).
- Higher overhead but provides full original packet protection.

Q8(b) — 2.25 marks: RFC 4301 Services

2020 Q8(b) [2.25 marks]

List and explain the security services defined by RFC 4301 for IPsec.

Solution

RFC 4301 defines **six security services** for IPsec:

1. **Access control** — enforces policy on which IP traffic is allowed (discard, bypass, or protect).
2. **Connectionless integrity** — detects modification of individual IP datagrams without requiring a persistent connection.
3. **Data origin authentication** — verifies that the packet came from the claimed source.
4. **Rejection of replayed packets (anti-replay)** — uses a sliding window and sequence numbers to detect and drop replayed datagrams.
5. **Confidentiality (encryption)** — encrypts the contents of IP packets so only authorized parties can read them (provided by ESP).
6. **Limited traffic flow confidentiality** — conceals traffic patterns (e.g.,

source/destination) in tunnel mode.

Q8(c) — 2.25 marks: Application Areas + Session/Connection State

2020 Q8(c) [2.25 marks]

What are the application areas of IPsec? Explain session state and connection state.

Solution

Application Areas:

1. Secure branch-office connectivity (site-to-site VPN)
2. Secure remote access VPN for employees
3. Secure B2B extranet connections with trading partners
4. Enhanced e-commerce security for customer transactions

Session State vs Connection State:

- **Connection state:** maintained per Security Association (SA). Each SA stores: SPI, sequence number counter, anti-replay window, cryptographic keys, SA lifetime, and mode (transport/tunnel). One SA = one unidirectional connection.
- **Session state:** a logical grouping of two SAs (one in each direction) forming a bidirectional secure session between two entities.
- IPsec itself is **stateless at the packet level** (each datagram processed independently based on the SA), but the SA database (SAD) holds connection state that persists for the SA's lifetime.

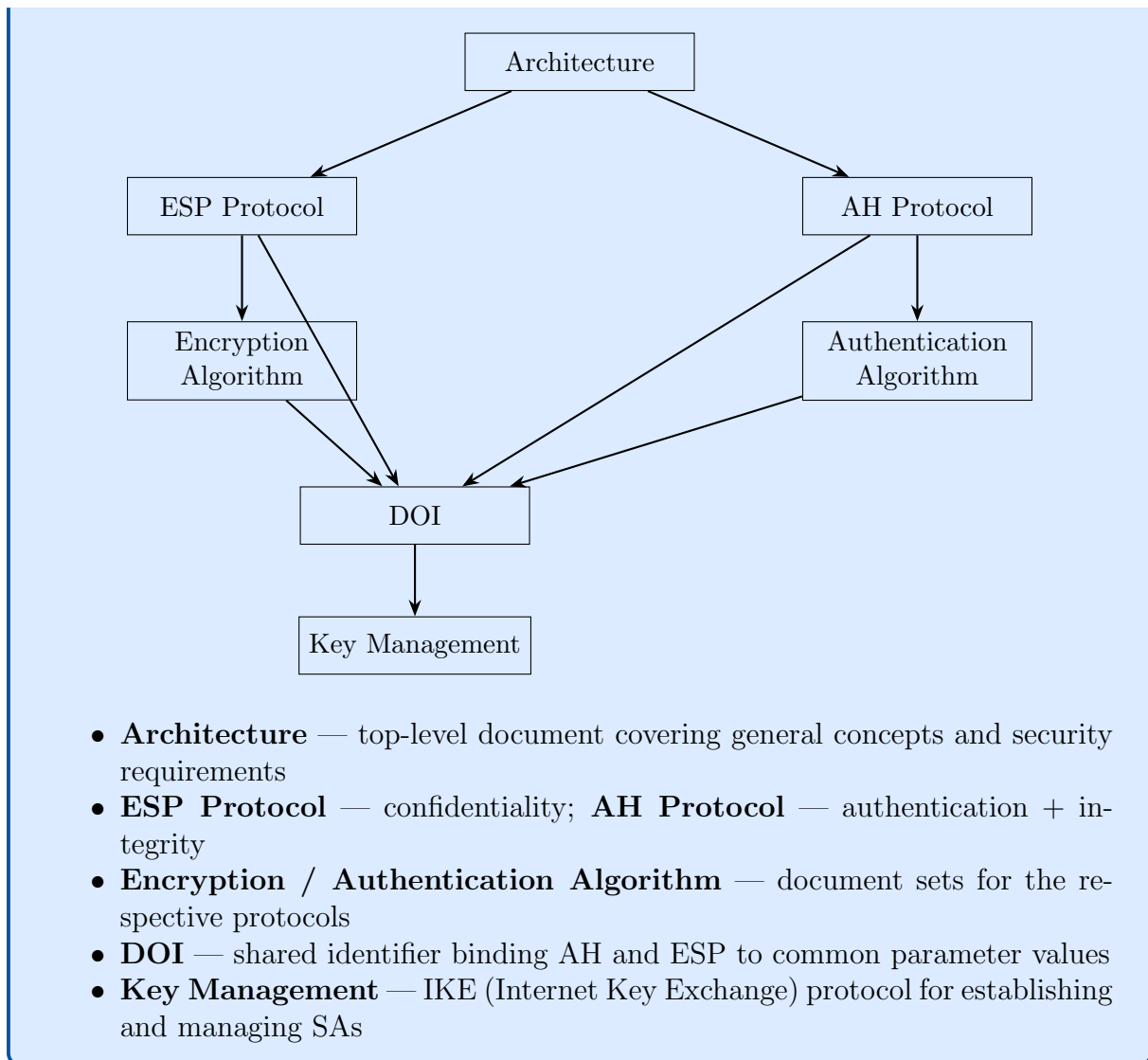
Q8(d) — 2 marks: Architecture

2020 Q8(d) [2 marks]

Draw and explain the IPsec architecture.

Solution

IPsec Architecture (per Lc#7 Slide 16):



Exam Strategy

Recurring Sub-Question Cluster (2020, 2021, 2024)

Sub-question	2020	2021	2024
Architecture (diagram + explanation)	Q8(d) 2m	Q4(c) 2.5m	Q5(c) 3m
Transport vs Tunnel mode	Q8(a) 2.25m	—	—
RFC 4301 services	Q8(b) 2.25m	—	—
Application areas	Q8(c) 2.25m	Q4(b) 2.5m	—
Session vs connection state	Q8(c) 2.25m	Q4(b) 2.5m	—
Security Associations	—	—	Q5(c) 3m

Architecture is the most reliable repeat (appears 2020, 2021, 2024 — all 3 years). Draw the diagram even if not explicitly asked.

Mnemonics:

- **ESP = Encrypt** (E = Encrypt); **AH = Auth + Integrity** (A = Auth)
- RFC 4301 services: **ACC-D-RC** — Access control, Connectionless integrity, data origin auth, Duplicate/replay rejection, Confidentiality, traffic flow Confidentiality (limited)